

Web Application Security Assessment Report

Date: 24 February 2026

Simulation Program: Commonwealth Bank Cybersecurity Virtual Experience (Forage)

1. Executive Summary

As part of the Commonwealth Bank Cybersecurity Virtual Experience Program, a structured web application security assessment was conducted using HackThisSite Basic Challenges (Levels 1–11). The objective was to identify common web vulnerabilities, understand exploitation techniques, and evaluate security control weaknesses aligned with OWASP Top 10 principles.

2. Scope

Target Environment: HackThisSite – Basic Web Challenges (Levels 1–11)

Testing Type: Guided Black-Box Testing

Access Level: External User Perspective

Objective: Identify vulnerabilities and recommend remediation strategies

3. Methodology

The assessment followed a structured security testing approach including:

- Reconnaissance via source code inspection and page analysis
- Enumeration of hidden fields, cookies, and accessible directories
- Manual input validation testing and parameter manipulation
- Injection payload testing (SSI, Command, SQL)
- Validation of successful exploitation and documentation of impact

4. Summary of Key Findings

Broken Access Control: Client-side authentication, directory traversal, and hidden field exposure allowed unauthorized access.

Injection Vulnerabilities: Identified Server-Side Include Injection, OS Command Injection, and SQL Injection due to unsanitized user input.

Session Management Weakness: Authentication relied on modifiable client-side cookies without integrity validation.

Cryptographic Failures: Credentials were encoded using reversible methods instead of

secure hashing.

Security Misconfiguration: Backup files and development artifacts were publicly accessible.

Insecure Design: Business logic flaws enabled unintended workflow manipulation.

5. Risk Assessment

Injection vulnerabilities (SSI, Command, SQL) were assessed as Critical due to potential remote code execution and database compromise risks. Broken access control and session management weaknesses were assessed as High risk. These findings demonstrate how insufficient input validation and server-side enforcement can significantly impact confidentiality, integrity, and availability.

6. Recommendations

- Enforce strict server-side authentication and authorization controls.
- Implement parameterized queries and prepared statements to prevent SQL injection.
- Sanitize and validate all user input using allowlist validation techniques.
- Secure session cookies using HttpOnly, Secure, and integrity protection mechanisms.
- Remove sensitive information from client-side code and restrict access to backup files.
- Adopt secure coding practices aligned with OWASP Top 10 guidelines.

7. Conclusion

This exercise provided foundational exposure to common web application vulnerabilities and reinforced the importance of secure design, input validation, and defense-in-depth strategies. The structured assessment process aligns with industry-standard penetration testing methodology and strengthened practical understanding of real-world web security risks.